

Tiny Second-hand Shopping Platform 개발 보고서

1. 개요

본 프로젝트는 시큐어코딩 과제의 요구사항을 만족하기 위해 개발한 작은 중고거래 상점 플랫폼이다. 사용자는 회원가입 후 판매 상품을 등록하고, 다른 사용자의 상품을 검색, 찜, 장바구니 담기, 구매 확정, 문의할 수 있다. 구현 과정에서는 기능 완성뿐 아니라 웹 애플리케이션에서 자주 발생하는 인증, 인가, SQL Injection, XSS, CSRF, 세션 관리, 입력 검증 문제를 줄이는 것을 목표로 하였다.

2. 요구사항 분석

2.1 기능 요구사항

- 회원 관리: 회원가입, 로그인, 로그아웃
- 상품 관리: 상품 등록, 상세 조회, 검색, 카테고리 필터, 판매 상태 필터, 본인 상품 수정
- 거래 기능: 찜하기, 장바구니, 구매 확정, 주문 내역
- 커뮤니케이션: 구매자와 판매자 간 상품 문의
- 사용자 페이지: 본인 판매 상품과 찜한 상품 확인
- 제출 문서: README, 테스트 체크리스트, 개발 보고서 PDF

2.2 보안 요구사항

- 비밀번호를 평문으로 저장하지 않는다.
- 인증된 사용자만 판매, 찜, 장바구니, 주문, 문의 기능을 사용할 수 있다.
- 본인 상품만 수정하거나 상태 변경할 수 있다.
- 모든 상태 변경 요청은 CSRF 공격으로부터 보호한다.
- 사용자 입력값은 저장 전 검증하고 출력 전 이스케이프한다.
- SQL Injection을 방지하기 위해 문자열 결합 쿼리를 사용하지 않는다.
- 세션 토큰은 예측 불가능해야 하며 쿠키 속성을 안전하게 지정한다.
- 보안 헤더를 적용해 브라우저 기반 공격을 완화한다.

3. 시스템 설계

3.1 기술 스택

- 언어: Python 3
- 웹 서버: Python 표준 라이브러리 http.server
- 데이터베이스: SQLite
- 프론트엔드: HTML, CSS, JavaScript
- 외부 의존성: 없음

외부 패키지를 사용하지 않도록 설계하여 제출 환경에서 설치 오류가 발생할 가능성을 줄였다. 데이터베이스는 최초 실행 시 자동으로 생성되며, 데모 계정과 예시 상품도 자동 등록된다.

3.2 데이터베이스 구조

- users: 회원 정보와 비밀번호 해시
- sessions: 서버 세션, CSRF 토큰, 만료 시간
- products: 상품 정보, 판매자, 가격, 상태
- favorites: 찜한 상품

- cart_items: 장바구니
- orders, order_items: 주문과 주문 상품
- messages: 상품 문의
- login_attempts: 로그인 시도 제한 기록
- audit_logs: 주요 상태 변경 기록

3.3 주요 화면

- /: 상품 목록, 검색, 필터
- /register: 회원가입
- /login: 로그인
- /products/new: 판매 등록
- /products/{id}: 상품 상세 및 문의
- /products/{id}/edit: 본인 상품 수정
- /dashboard: 내 상점
- /cart: 장바구니
- /orders: 주문 내역
- /messages: 문의 내역

4. 구현 내용

4.1 인증과 세션

회원 비밀번호는 PBKDF2-SHA256으로 해시한다. 사용자별 16바이트 salt를 생성하고 210,000회 반복하여 저장한다. 로그인에 성공하면 난수 기반 세션 토큰을 발급하고, 데이터베이스에는 토큰 원문이 아니라 SHA-256 해시만 저장한다. 쿠키에는 HttpOnly, SameSite=Lax, Max-Age, Path=/ 속성을 지정하였다.

4.2 상품과 거래 기능

상품은 제목, 설명, 카테고리, 상품 상태, 가격, 거래 지역, 이미지 URL을 가진다. 판매자는 본인 상품을 수정하고 판매 상태를 바꿀 수 있다. 구매자는 타인의 판매중 상품만 장바구니에 담을 수 있으며, 구매 확정 시 주문이 생성되고 해당 상품 상태가 판매완료로 변경된다.

4.3 문의 기능

상품 문의는 구매자와 판매자 사이에서만 조회되도록 제한하였다. 상품 상세 페이지에서 로그인하지 않은 사용자는 문의 내역을 볼 수 없고, 로그인 사용자도 자신이 보낸 문의 또는 자신이 판매자인 상품의 문의만 볼 수 있다.

5. 보안 약점과 대응

확인한 보안 약점	위험	변경 및 대응
평문 비밀번호 저장 가능성	DB 유출 시 계정 탈취	PBKDF2-SHA256, 사용자별 salt, 반복 해시 적용
세션 토큰 원문 저장	DB 유출 시 세션 탈취	세션 토큰은 쿠키에만 두고 DB에는 SHA-256 해시 저장
SQL Injection	인증 우회, 데이터 유출/변조	모든 SQL에 ? 파라미터 바인딩 사용
Stored/Reflected XSS	세션 탈취, 악성 스크립트 실행	출력 시 html.escape 적용, CSP 적용

확인한 보안 약점	위험	변경 및 대응
CSRF	사용자 의도와 무관한 상품 등록/주문	로그인 세션별 CSRF 토큰 생성 및 POST 검증
IDOR	타인 상품 수정/상태 변경	seller_id == current_user.id 검사
Broken Access Control	본인 상품 구매, 타인 메시지 열람	구매 가능 상태와 소유자 검사, 메시지 조회 범위 제한
무차별 로그인 시도	비밀번호 추측 공격	15분 내 8회 이상 실패 시 차단
위험한 이미지 URL	javascript: 등 스크립트 스킴 악용	http와 https URL만 허용
Clickjacking	iframe 내 사용자 클릭 유도	X-Frame-Options: DENY, CSP frame-ancestors 'none'
MIME Sniffing	잘못된 콘텐츠 해석	X-Content-Type-Options: nosniff
과도한 요청 본문	메모리 사용량 증가	요청 본문 1MB 제한

6. 테스트

6.1 정적 검사

```
python -m py_compile .Wapp.py
```

Python 문법 오류가 없는지 확인하였다.

6.2 자동 스모크 테스트

```
python .WtestsWsmoke_test.py
```

테스트는 임시 포트에서 서버를 실행하고 다음 항목을 확인한다.

- 메인 페이지 정상 응답
- CSP 보안 헤더 존재
- 회원가입 및 로그인 성공
- 세션 쿠키 발급
- CSRF 토큰 없는 상품 등록 차단
- CSRF 토큰 있는 상품 등록 성공
- XSS 페이로드 이스케이프 확인
- 다른 사용자의 상품 수정 차단

6.3 수동 테스트 체크리스트

별도 파일 docs/test_checklist.md에 기능 요구사항과 보안 점검 항목을 정리하였다.

7. 유지보수 계획

- 배포 전 SECRET_KEY 기반 서명 쿠키 또는 HTTPS 환경의 Secure 쿠키 적용을 검토한다.
- 실제 서비스에서는 이미지 업로드를 별도 스토리지에 저장하고 확장자, MIME, 용량, 악성 파일 검사를 추가한다.
- 주문/결제는 외부 결제 모듈과 연동하고 결제 검증 콜백을 서버에서 검증한다.
- 관리자 페이지를 추가할 경우 역할 기반 접근 제어와 감사 로그 조회 기능을 분리한다.
- 정기적으로 의존성 보안 점검을 수행한다. 현재 버전은 외부 패키지가 없어 공급망 위험을 줄였다.

8. AI 도구 활용

개발 과정에서 AI 도구를 요구사항 분석, 보안 위협 모델링, 기능 목록 정리, 테스트 체크리스트 작성, 보고서 초안 작성, 코드 리뷰 관점의 취약점 점검에 적극 활용하였다. 특히 중고거래 플랫폼에서 필요한 인증/인가, 상품 등록, 장바구니, 주문, 문의 기능을 빠르게 도출하고 각 기능별 보안 약점을 함께 점검하는 데 활용하였다.

9. 실행 방법

```
cd "C:\Users\user\OneDrive\문서\키보드 부채널\tiny-secondhand-secure"  
python .\wapp.py
```

접속 주소는 <http://127.0.0.1:8000>이다. 데모 계정은 README에 명시하였다.

10. GitHub Repository

완성한 프로그램은 public GitHub repository에 업로드한다.

- Repository: <https://github.com/spe4r1/Tiny-Second-hand-Shopping-Platform>